

CACADEMY

FORMAÇÃO AVANÇADA
EM CIBERSEGURANÇA

www.cncs.gov.pt

Ciclo de Negócio em Cibersegurança

Nível F

35 horas

Ciclo de negócio em cibersegurança

Módulo 4, Sessão #1 e #2

- 1. Gestão de terceiros (TPRM) - revisão**
- 2. Enquadramento da ISO 27036**
- 3. Sistema de gestão de fornecedores**
- 4. Controlos da ISO 27036**
- 5. Check-list para o CISO e instrumentos de gestão**
- 6. Casos de aplicação**

Boas vindas e Introdução

Plano de estudos

9 sessões, totalizando 35 horas de curso, com cinco módulos principais

1.	2.	3.	4.	5.
Estado da Arte e modelo estratégico CISO	<i>Framework</i> SbD e mapa de dependências	Risco de <i>3rd Party</i> e <i>Vendor Management</i>	Gestão <i>3rd Party</i> e a visão colaborativa	Desafios na Era da IA
O tema da confiança na NIS2	Sec. by Design (SbD)	Boas práticas TPRM	ISO 27001 e ISO 27036	IA riscos e ameaças
Modelo de decisão do CISO	<i>Frameworks</i> de trabalho	Política, controlos e <i>Cloud</i>	Requisitos de gestão; controlos	IA GRC e 3rd Party
Caso InterMed 1	Caso InterMed 2	Caso InterMed 3	Caso InterMed 4	Caso InterMed 5

Quiz

Exemplos

Artefactos

Casos

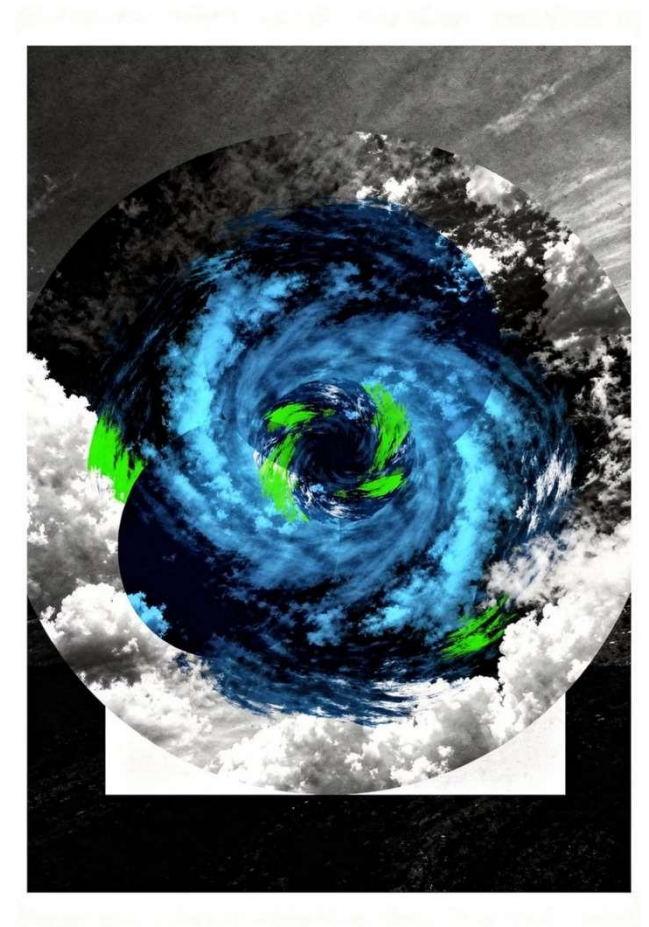
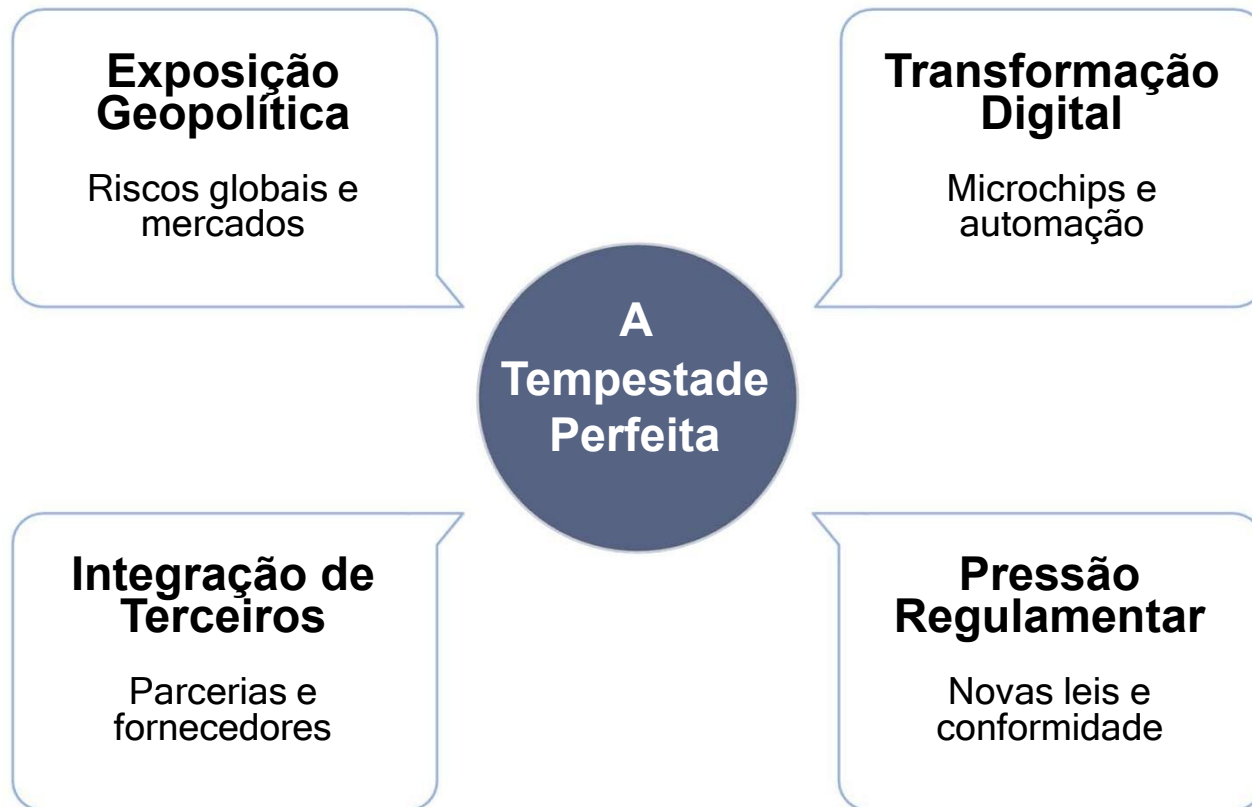
Agenda

Módulo 4 (S1, S2)

- 1. Gestão de terceiros (TPRM) – revisão
- 2. Enquadramento da ISO 27036
- 3. Sistema de gestão de fornecedores
- 4. Controlos da ISO 27036
- 5. Check-list para o CISO e instrumentos de gestão
- 6. Casos de aplicação

Gestão de terceiros (revisão)

As Forças Centrais em Jogo



O perímetro real da organização: gerir terceiros



"Os terceiros não são apenas uma extensão da operação; são uma extensão do risco e, quando bem geridos, **também uma extensão da resiliência.**"



Continuidade

Gerir terceiros é gerir a capacidade de manter operação em crise



Confiança

A reputação da organização depende da maturidade dos seus parceiros



Compliance

A responsabilidade regulatória não se delega ao fornecedor

Como sabemos que é real?

A QUEDA EM DOMINÓ



Um incidente num fornecedor pode transformar-se rapidamente num incidente de negócio do cliente.



El Corte Inglés Portugal



O que aconteceu

Em março de 2025, um fornecedor externo foi alvo de acesso não autorizado a dados de clientes de cartão, afetando também clientes em Portugal.

Ficaram comprometidos dados de identificação, contacto e números de cartões de compras.

Lição Principal

⚠ Quem responde perante clientes e regulador continua a ser a organização responsável, mesmo quando a origem do incidente está no fornecedor externo.

- O incidente ocorreu no ecossistema do fornecedor, não no perímetro do retalhista
- Necessidade de avaliar subcontratados com acesso a dados e meios de pagamento



Qual é o principal risco evidenciado neste caso de *3rd party*?

- a) Falha técnica interna do retalhista que provocou indisponibilidade do sistema
- b) Exposição de dados devido a fornecedor com acesso sensível sem os controlo adequados
- c) Falta de investimento em infraestrutura
- d) Ataque direto ao cliente final

Quiz

Enquadramento ISO 27036

Lógica de gestão

Ciclo de vida ISO 27036

NIS2 e a Segurança da Cadeia de Abastecimento

O Regulamento de Execução (UE) 2024/2690 concretiza os requisitos técnicos do artigo 21.º, n.º 2, da Diretiva NIS2. Entre os 13 domínios cobertos, a **segurança da cadeia de abastecimento** surge como capítulo autónomo, dependendo fortemente de outros domínios.



Política de Supply Chain

Reger relações com fornecedores diretos e prestadores, mitigando riscos para sistemas e redes

CrITÉRIOS de Seleção

Práticas de cibersegurança, resiliência, certificações, histórico de incidentes e vendor lock-in

Cláusulas Contratuais

Notificação de incidentes, direito de auditoria, gestão de vulnerabilidades e obrigações de fim de contrato

Monitorização Contínua

Revisão anual da política, acompanhamento de SLAs e processo de saída com revogação de acessos

Enquadramento Regulatório e Normativo — Gestão de Terceiros

NIS2 · ENISA · ISO 27001 · ISO 27036 como instrumentos de execução TPRM

NIS2 Directiva (UE) 2022/2555

- Art. 21.º — obrigação de gerir riscos de SI em fornecedores e cadeia de abastecimento
- Abrange entidades essenciais e importantes: financeiro, saúde, infra-crítica
- Sanções até €10M ou 2% vol. neg. global
- Medidas: due diligence, cláusulas, monitorização e reporte de incidentes

ENISA Directrizes e Relatórios

- Relatório de ameaças a supply chain (2021-2024)
- Guidelines TPRM para operadores de serviços essenciais
- Framework de avaliação de risco de fornecedores críticos
- Alinhamento com ISO 27036 e NIST SP 800-161

ISO 27001:2022 Gestão de SI

- A.5.19 - 5.23: controlos específicos de segurança em fornecedores
- Anexo A: 9 controlos dedicados a relações com terceiros
- SoA (Statement of Applicability) inclui TPRM
- Base para exigir evidência de conformidade ao fornecedor

ISO/IEC 27036 Instrumento de execução

- Parte 1: Visão geral e conceitos
- Parte 2: Requisitos – ciclo de vida e controlos
- Parte 3: Supply chain de TIC (hardware, software)
- Complementa ISO 27001 com detalhe operacional de TPRM

Anexo - requisitos operacionais para terceiros (ENISA)

Política de Supply Chain

A entidade deve estabelecer, implementar e aplicar uma política de segurança da cadeia de abastecimento para reger as relações com fornecedores diretos e prestadores de serviços, identificando o seu papel na cadeia e comunicando-o aos fornecedores relevantes.

CrITÉrios de Seleção

Os critérios devem incluir práticas de cibersegurança dos fornecedores, capacidade de cumprir especificações, qualidade e resiliência dos produtos e serviços TIC, diversificação de fornecimento e limitação de vendor lock-in.

Registo de Fornecedores

Manter registo atualizado de fornecedores diretos e prestadores, incluindo PoC e os produtos, serviços e processos TIC fornecidos, com classificação por criticidade atualizada pelo menos anualmente.

Fatores ENISA Adicionais

- Jurisdição legal e estrutura acionista
- Histórico de incidentes e vulnerabilidades
- Dependência de subfornecedores
- Certificações e relatórios de avaliação
- Nível de transparência do fornecedor
- Capacidade de resposta a incidentes



A supervisão não termina na contratação – a política deve ser revista pelo menos anualmente e incidentes devem desencadear revisões não planeadas.

ISO 27036 enquanto instrumento de gestão

A ISO/IEC 27036 responde a **cinco perguntas críticas**:



- **Que terceiros importam?**
- **Que requisitos de segurança impor?**
- **Como verificar evidência?**
- **Como gerir mudança e incidente?**
- **Como terminar sem perda de controlo?**

ISO/IEC 27036: arquitetura em camadas

A norma deve ser lida como uma **arquitetura metodológica** que complementa – sem substituir – um ISMS (Sistema de gestão) conforme a ISO 27001.



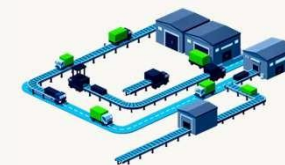
Parte 1 — Conceitos e Riscos

Introduz a lógica das relações cliente-fornecedor, papéis, responsabilidades e riscos típicos de governação deficiente, dependências e fragilidade na gestão de subfornecedores



Parte 2 — Requisitos Cliente-Fornecedor

Núcleo normativo com estratégia, processos organizacionais e ciclo operacional de cinco etapas: planeamento, seleção, acordo, gestão e terminação



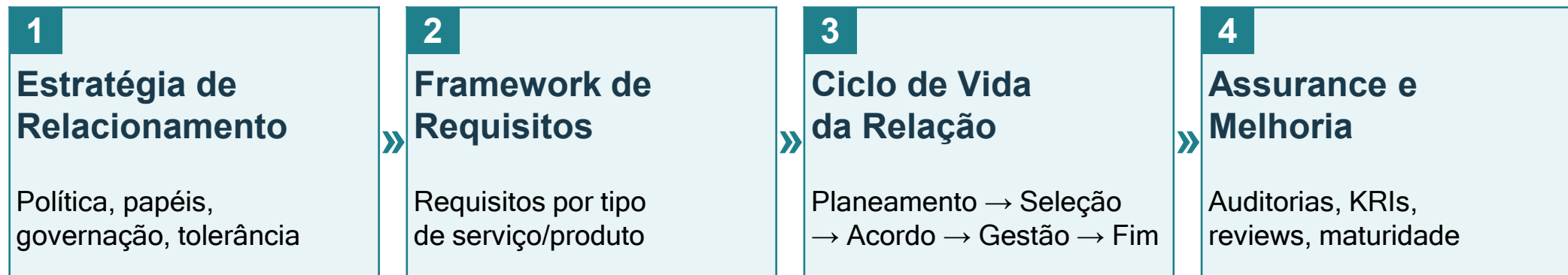
Parte 3 — Segurança da Cadeia de Abastecimento

Expande o modelo para hardware, software e serviços, integrando processos de ciclo de vida da ISO/IEC/IEEE 15288 e 12207, desde aquisição até disposição final

ISO/IEC 27036: lógica de sistema de gestão

A ISO 27036 não substitui um ISMS, mas pressupõe e complementa uma gestão sistemática de risco. A existência de um ISMS conforme a ISO/IEC 27001 ajuda a tratar riscos da supply chain, **desde que o âmbito inclua as áreas que estabelecem e mantêm relações com fornecedores.**

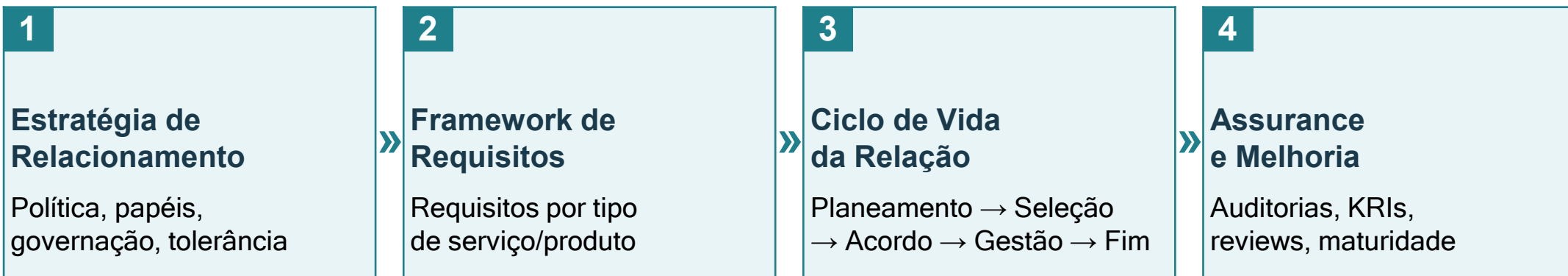
4 CAMADAS INTEGRADAS DA ISO/IEC 27036



ISO/IEC 27036 – Lógica da Norma e Ciclo de Vida TPRM

Sistema de Gestão de Terceiros: 4 camadas integradas · 5 etapas do ciclo de vida

4 CAMADAS INTEGRADAS DA ISO/IEC 27036



ISO/IEC 27036 – Lógica da Norma e Ciclo de Vida TPRM

Sistema de Gestão de Terceiros: 4 camadas integradas · 5 etapas do ciclo de vida

5 ETAPAS DO CICLO DE VIDA (ISO/IEC 27036 Parte 2)



ISO 27036: visão do ciclo de vida do fornecedor

Planeamento

Classificação por criticidade, framework de requisitos e critérios de seleção.

Terminação Controlada

Destruição segura, revogação de acessos e preservação de evidência forense.

Monitorização

Inventário, patching, rastreabilidade e logging contínuos.



Seleção

Due diligence, avaliação de maturidade e gestão de subfornecedores.

Acordo / Contrato

Cláusulas verificáveis, direito de auditoria, SBoM e plano de exit.

Gestão Contínua

Conformidade, KPIs/KRIs, incidentes e controlo de alterações.

Etapas 1,2,3: Planeamento, Seleção e Acordo



Planeamento

Classificação de terceiros por criticidade, framework de requisitos, critérios de seleção e planos de terminação.



Seleção

Due diligence, avaliação de maturidade, certificações, capacidade de remediação e gestão de subfornecedores.



Acordo

Cláusulas verificáveis: incidentes, change management, direito de auditoria, SBoM, integridade e plano de exit.

Etapas 4,5,6 Gestão, Monitorização e Terminação



Gestão Contínua

Monitorização de conformidade e KPIs/KRIs, gestão integrada de incidentes e vulnerabilidades, controlo de alterações com aprovação atempada.

Acompanhamento das certificações (ex: Cloud e CSA Alliance STAR Program)



Monitorização

Inventário, patching, rastreabilidade e logging contínuos.

Scoring de segurança do 3rd Party (ex: Bitsight)



Terminação Controlada

Inventário final de ativos e dados, destruição segura com certificado, revogação de acessos, preservação de evidência forense e cadeia de custódia até ao fecho.

Offboarding formalizado.

Controlos principais por etapa do ciclo de vida

Etapa	Objetivo Executivo	Controlos Principais	Artefactos Ilustrativos
1 Planeamento	Definir modelo de governação e risco	Estratégia TPRM · Classificação de terceiros · Framework de requisitos · Critérios de seleção · Planos de transição	Política de TPRM · Matriz de criticidade · Baseline de requisitos por tipologia
2 Seleção	Escolher fornecedor com capacidade comprovada	Due diligence seg. e continuidade · Avaliação de certificações · Análise de vulnerabilidades · Gestão de subfornecedores	Questionário de Due Diligence · Scorecard · Evidência ISO 27001 · Relatório de due diligence
3 Acordo	Converter requisitos em obrigações verificáveis	Cláusulas SI e reporting · Gestão de alterações · Gestão de incidentes · Direito de auditoria · Terminação e transição · SBoM / integridade	Contrato + Anexo SI · DPA / NDA · Playbook incidentes · Plano de exit
4 Gestão	Manter controlo durante a operação	Monitorização contínua · Ações corretivas · Revalidação periódica · Controlo de mudanças · Incidentes e vulnerabilidades · Inventário e patching	KPI/KRI Dashboard · Relatórios de serviço · Registo de issues e logs
5 Terminação	Fechar relação sem exposição residual	Inventário final de ativos e dados · Devolução / destruição · Revogação de acessos · Preservação de evidência · Cadeia de custódia	Checklist de offboarding · Certificado de destruição · Registo de transferência

Segundo a ISO 27036, qual é a abordagem mais adequada para gerir segurança e gestão do risco ao longo do ciclo de vida de terceiros?

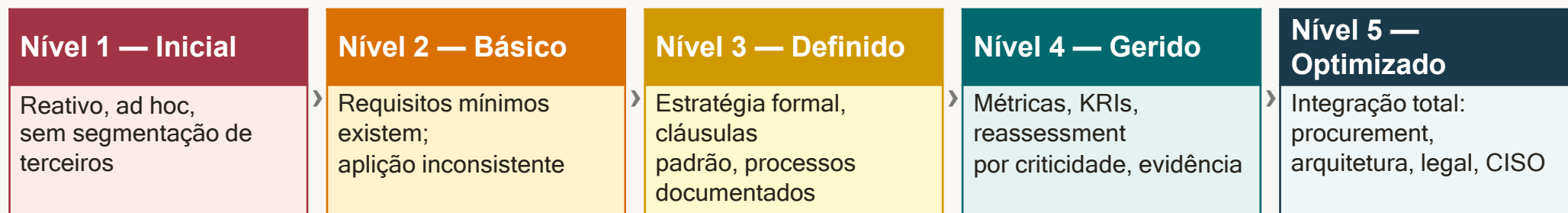
- a) Avaliar o fornecedor apenas durante o processo inicial de procurement
- b) Focar exclusivamente nos controlos técnicos implementados pelo fornecedor
- c) Aplicar *governance*, avaliação do risco, monitorização e controlos ao longo de todo o ciclo de vida da relação com terceiros
- d) Transferir a responsabilidade de segurança integralmente para o fornecedor através de cláusulas contratuais

Quiz

Check-list (exemplos práticos)

PLANEAMENTO & SELEÇÃO	ACORDO & GESTÃO CONTÍNUA	TERMINAÇÃO
P ☐ Política TPRM aprovada pela gestão de topo	A ☐ Cláusulas de SI e SLAs de segurança no contrato	T ☐ Inventário final de ativos e dados do fornecedor
P ☐ Terceiros segmentados por criticidade e acesso	A ☐ Direito de auditoria e acesso a evidência	T ☐ Revogação de acessos e credenciais em 24h
P ☐ Framework de requisitos mínimos por tipologia	A ☐ Notificação incidentes $\leq 24h$ RCA ≤ 5 dias úteis	T ☐ Destruição / devolução de dados com certificação
S ☐ Due diligence de segurança e continuidade realizado	A ☐ Cláusula change-of-control e plano de exit	T ☐ Cadeia de custódia documentada até ao fecho
S ☐ Certificações verificadas (ISO 27001, SOC 2)	G ☐ Monitorização de KPIs/KRIs de segurança activa	T ☐ Preservação de evidência conforme retenção legal
S ☐ Gestão de upstream suppliers avaliada	G ☐ Revalidação anual do risco por fornecedor crítico	T ☐ Plano de transição para novo fornecedor executado
S ☐ Capacidade BC/DR validada (RTO/RPO)	G ☐ Controlo de alterações com aprovação formal	T ☐ Lições aprendidas documentadas e integradas no TPRM
Tags: P = Planeamento · S = Seleção · A = Acordo · G = Gestão · T = Terminação		

Visão da maturidade



Governança	Existê estratégia e ownership claro?	Política, papéis, comité, reporting
Risco	Terceiros são classificados e reavaliados?	Matriz criticidade, KRIs, periodicidade
Seleção	A segurança influencia a escolha?	Scorecards, due diligence, upstreams
Contrato	O acordo traduz requisitos verificáveis?	Cláusulas, auditoria, incidentes, exit

Assurance	Há verificação independente?	Reviews, auditorias, evidência, ações
Supply Chain Técnica	Há visibilidade sobre software/hardware?	SBoM, hashes, signing, custódia
Resiliência	Existe capacidade para incidente e exit?	Playbooks, planos continuidade, testes

Onde se encontra a sua Organização?



Qual é o principal indicador de maturidade organizacional no contexto de DORA?

- a) Possuir apenas documentação de conformidade atualizada
- b) Demonstrar capacidade contínua de gerir risco e manter resiliência operacional, perfazendo ciclos de gestão com melhoria contínua
- c) Externalizar a maioria dos serviços tecnológicos críticos
- d) Realizar auditorias apenas quando exigido pelo regulador

Quiz

Controlos de gestão ISO 27036

Impactos para o CISO

Instrumentos de aplicação para o CISO

Etapa 1: Planeamento da Relação

O *supplier relationship planning process* exige documentar a decisão de aquisição e as considerações de segurança associadas. É aqui que se define a **proporcionalidade do modelo** e a criticidade do terceiro – evitando comprar primeiro e discutir segurança depois.

Avaliação de Risco Pré-contratual

Risk assessment proporcional à criticidade – ex.: MSSP com acesso privilegiado vs. fornecedor sem acesso lógico

Requisitos Legais e Regulatórios

Checklist regulatória, privacidade, export control – ex.: localização de dados compatível com RGPD e obrigações setoriais

Requisitos Mínimos de Segurança

Baseline control set: MFA, logging, segregação, BCP, criptografia e direito de auditoria para fornecedor crítico

Identificação de Ativos e Owners

Inventário de aplicações, bases de dados e integrações que o terceiro irá tocar

Etapa 2: Seleção do Fornecedor

Seleção não é um "questionário de ciber" isolado – é uma **decisão multidimensional** que separa fornecedor "aceitável" de fornecedor "conveniente".

Critérios ISO/IEC 27036

- Aceitação dos requisitos de segurança
- Maturidade e possibilidade de auditoria
- Capacidade operacional e robustez financeira
- Transparência sobre subcontratantes
- Aceitação de transição e terminação

Fatores Adicionais ENISA

- Práticas de secure development
- Resiliência e riscos de vendor lock-in
- Histórico de incidentes e vulnerabilidades
- Dependências da cadeia a montante
- Enquadramento jurídico e jurisdição

 **Artefactos essenciais:** matriz de avaliação com scoring, questionário de due diligence, certificações, relatórios SOC/pentest e parecer de segurança para adjudicação.

Etapa 3: Acordo e Contratualização

É aqui que a **arquitetura de controlo ganha força executória**. Sem contrato correto, monitorização, auditoria, remediação e saída segura tornam-se frágeis ou litigiosas.



Segurança e SLAs

RTO, RPO, tempos de notificação e prazo de correção de vulnerabilidades críticas



Change Management

Fornecedor não pode alterar arquitetura, localização de dados ou subcontratante crítico sem aprovação prévia



Gestão de Incidentes

Notificação imediata, triagem conjunta e atualização periódica – ex.: ransomware no fornecedor



Direito de Auditoria

Relatório anual de auditoria mais evidências adicionais quando houver incidentes graves



Transição e Terminação

Plano de saída com handover, proteção de dados e período de transição assistida

Etapa 4: Gestão e Monitorização Contínua

Esta é a etapa em que o programa deixa de ser "**compliance by onboarding**" e se torna gestão real de risco. Muitos incidentes graves decorrem de degradação do controlo com o tempo, mudanças não governadas ou shadow subcontracting.

Monitorização de SLA e Controlos

Dashboards, service reviews mensais – uptime, incidentes abertos, vulnerabilidades e execução de planos corretivos

Gestão de Incidentes e Vulnerabilidades

Incident logs, RCA e planos de remediação – vulnerabilidade crítica em componente do fornecedor desencadeia mitigação e comunicação

Reavaliação por Mudança Significativa

Mudança de controlo acionista do fornecedor exige reavaliação jurídica e de risco com adenda contratual

Auditorias e Ações Corretivas

Audit reports e PAC - plano de ações corretivas, numa lógica de melhoria e mudança

Etapa 5: Terminação e Saída Segura

A etapa mais **negligenciada** e uma das mais críticas. Uma relação mal encerrada deixa acessos ativos, cópias não destruídas e lacunas de responsabilidade precisamente quando a capacidade de influência sobre o fornecedor já está a diminuir.



Termination Plan e Governance

Responsável nomeado, cronograma e comunicação interna e a terceiros



Inventário de Ativos, Dados e Acessos

Contas VPN, APIs, bastions, backups e documentação na posse do fornecedor



Devolução, Retenção ou Destruição Segura

Certificates of destruction, registos de devolução – fornecedor apaga cópias e emite certificado



Revogação de Acessos e Handover

Remover contas nominativas, service accounts, chaves e acessos físicos; NDA pós-cessação

Conclusão: patamares essenciais



Terminar com Controlo e Prova

Saída segura, revogação de acessos, destruição certificada e handover documentado



Monitorizar Durante Toda a Vida Útil

SLA reviews, gestão de incidentes, reavaliação por mudança e auditorias com CAPA



Contratar com Cláusulas Executáveis

Segurança, notificação, auditoria, subcontratação e terminação no contrato



Selecionar com Critérios Objetivos

Matriz de avaliação, due diligence de evidências e parecer de segurança para adjudicação



Classificar Criticidade Antes de Comprar

Segmentar por criticidade, Risk assessment proporcional, risco aceitável definido e requisitos mínimos estabelecidos.

Orientação para o CISO

“Gerir terceiros é gerir o perímetro real da organização. ISO 27036 é o método — a decisão é do CISO.”

01

Obrigações Legais e Risco Operacional

- A NIS2 (Art. 21.º) impõe gestão de risco na cadeia de fornecimento.
- **Uma falha de segurança num fornecedor crítico** pode constituir incidente reportável e gerar responsabilidade regulatória directa para a organização.

02

ISO 27036 como método estruturado

- **A norma oferece uma framework estruturada, auditável e alinhada com ISO 27001.**
- Permite demonstrar a reguladores e auditores que a gestão de terceiros segue um processo repetível, documentado e proporcional ao risco.

03

Ciclo de Vida e Maturidade como KPIs

- O CISO deve monitorizar a maturidade TPRM por dimensão, com KRIs por etapa do ciclo de vida.
- **A meta operacional é nível 3+ para fornecedores críticos e nível 2+ para o universo geral de terceiros.**

Agenda Mínima para o CISO

A ISO/IEC 27036 deve ser tratada como **mecanismo de redução de risco operacional**, não como norma documental. Quatro capacidades são inegociáveis para terceiros críticos:



Requisitos Claros

Segmentar terceiros e normalizar cláusulas e artefactos.



Evidência Verificável

Exigir evidência proporcional ao risco e direito de auditoria.



Monitorização Contínua

Institucionalizar reassessment, service reviews e KRIs.



Saída Controlada

Incorporar controlos técnicos de supply chain e planos de exit.

Segmentação de fornecedores

NÍVEL 1 — CRÍTICO

Critério principal

Funções críticas/importantes; dados regulados; acesso privilegiado

Obrigações DORA

Arts. 28, 29, 30 completos; notificação CTPP; plano de exit formal

Artefactos exigidos

Contrato + Anexo SI · DPA/NDA · Questionário DD completo · Scorecard · KRIs mensais · Plano exit · Audit log

Reavaliação

Anual obrigatória + por evento (incidente, change-of-control, vulnerabilidade crítica)

Exemplos ilustrativos

Core banking (Temenos, Finastra) · Cloud provider (AWS, Azure) · Processador de pagamentos ·

NÍVEL 2 — IMPORTANTE

Critério principal

Impacto operacional indirecto; acesso a dados internos; substituição moderada

Obrigações DORA

Art. 30 parcial; due diligence adaptada; cláusulas-padrão reforçadas

Artefactos exigidos

Contrato + cláusulas SI · Questionário DD simplificado · Scorecard · KRIs trimestrais · Revisão anual

Reavaliação

Anual ou por evento relevante (mudança de escopo, incidente de segurança)

Exemplos ilustrativos

ERP (SAP, Oracle) · CRM (Salesforce) · Suporte de helpdesk externo · Serviços de auditoria externa

NÍVEL 3 — PADRÃO

Critério principal

Sem acesso a funções críticas nem a dados sensíveis; fácil substituição

Obrigações DORA

Cláusulas contratuais mínimas; registo no inventário de terceiros

Artefactos exigidos

Contrato com cláusulas-base · Registo no inventário · Questionário básico · Reavaliação bienal

Reavaliação

Bienal ou por evento (mudança de âmbito que eleve o risco)

Exemplos ilustrativos

Fornecedor de material de escritório · Serviço de traduções · Plataforma de e-learning sem acesso a dados pessoais ·

Segmentação de fornecedores - Execução

Matriz de Decisão — Classificação Rápida			
Critério	N1	N2	N3
Funções críticas ou importantes afectadas	●	○	—
Dados de clientes / dados regulados	●	○	—
Acesso privilegiado a sistemas core	●	○	—
Risco de concentração ou CTPP	●	○	—
Substituição difícil (> 6 meses)	●	○	—
Integração com rede interna / produção	●	○	—
Subfornecedores com risco de cadeia	○	●	—
Impacto operacional indirecto	○	●	—
Due diligence completa obrigatória	●	●	—
Reavaliação anual obrigatória (DORA)	●	●	○

Instrumentos para o CISO

1) Gestão de terceiros - Avaliação de maturidade



Relativamente gestão do risco dos terceiros, como avaliar a maturidade de uma organização



Aplicar ferramenta
de avaliação de
maturidade

https://guilhasn.github.io/ciclo_negocio_ciberseguranca/templates/Avaliacao_Maturidade_TPRM.xlsx

2) Gestão de terceiros - *Due diligence*



Como vamos avaliar o fornecedor crítico?

Qual é o grau de conformidade da com os requisitos aplicáveis?



Aplicar ferramenta
de Due Diligence

https://guilhasn.github.io/ciclo_negocio_ciberseguranca/templates/Questionario_Due_Diligence_Fornecedores.xlsx

Conclusão

A ISO 27036 reforça que a segurança não é apenas tecnologia

Cibersegurança é gestão do risco de terceiros

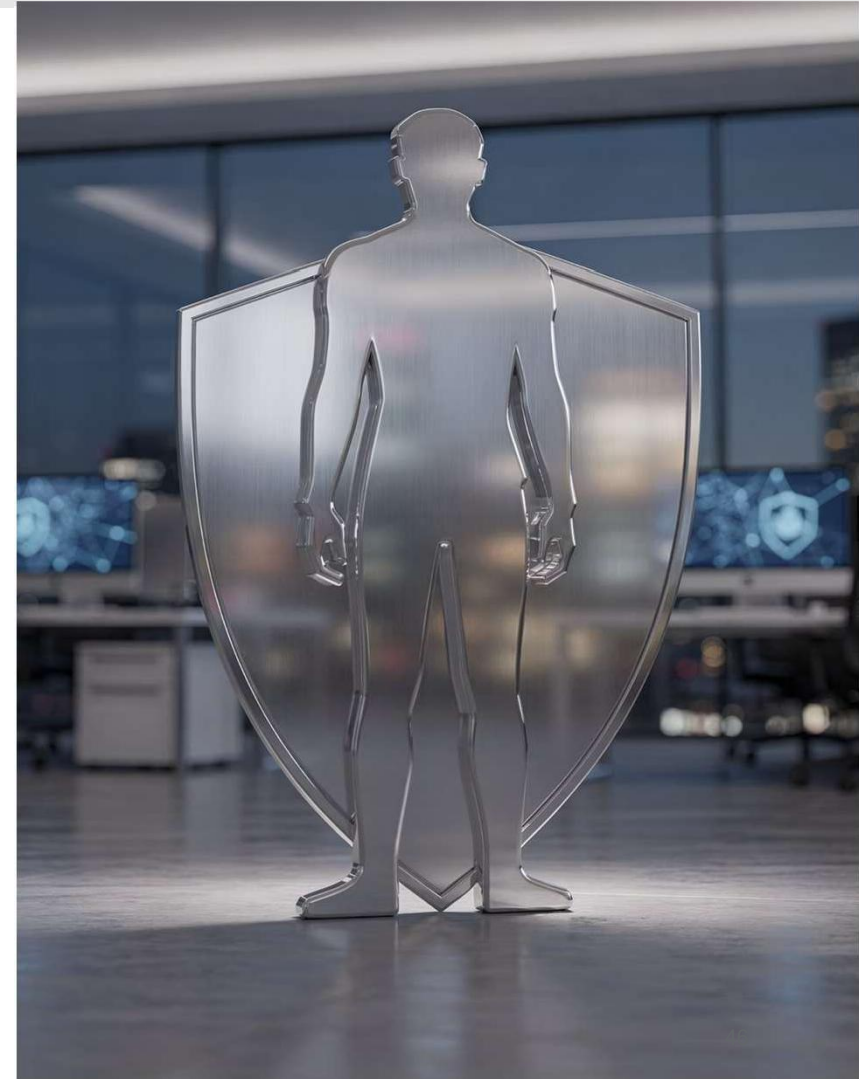
ISO 27036 contribui para a segurança na cadeia de fornecimento

Decisão e método = reduzir risco operacional

A segurança com terceiros deve existir durante todo o ciclo de vida da relação

Investimento real

A segurança de terceiros não começa na conformidade documental – começa na capacidade da organização para gerir risco de forma contínua.



Questões?

Obrigado!